



Servicios Gestionados de Ciberseguridad

MEMORIA TÉCNICA DEL PROYECTO

Infraestructura empresarial, monitorización y auditoría de seguridad

Proyecto	JAMSEC / Apex Gestoría
Versión	1.0
Fecha	1 de junio de 2026
Autor	Alex Sánchez García
Plataforma	Clúster Proxmox VE (3 nodos)

Índice

Índice	2
1. Introducción y contexto	3
2. Objetivos.....	4
3. Infraestructura de JAMSEC.....	5
4. Infraestructura del cliente (Apex Gestoría)	6
5. Monitorización: IDS/IPS/SIEM.....	7
6. Auditoría de seguridad	8
7. Incidencias y soluciones.....	9
8. Conclusiones	10
9. Anexos.....	11

1. Introducción y contexto

El presente proyecto desarrolla, de extremo a extremo, el caso de una empresa de ciberseguridad (JAMSEC) que despliega su propia infraestructura, monitoriza la de un cliente (Apex Gestoría) y realiza una auditoría de intrusión sobre ella, entregando los informes correspondientes.

La infraestructura se ha construido sobre un clúster Proxmox VE de tres nodos. Toda la configuración se ha realizado de forma reproducible mediante cloud-init y scripts versionados, sin reiniciar los nodos físicos del clúster en ningún momento, por requisito operativo.

2. Objetivos

- Montar una infraestructura empresarial propia (cortafuegos, DMZ, servicios separados, multirred).
- Montar por separado la infraestructura de un cliente.
- Implantar un IDS/IPS/SIEM que controle ambas infraestructuras.
- Auditar la infraestructura del cliente mediante pruebas de intrusión de distintos ámbitos.
- Elaborar un informe técnico y un informe ejecutivo de la auditoría.
- Documentar el proyecto y publicar el código en un repositorio.
- Preparar una demostración de la auditoría.

3. Infraestructura de JAMSEC

La infraestructura propia de JAMSEC se aloja en el nodo 'proxmox' y se segmenta en cuatro redes mediante un cortafuegos perimetral basado en Debian 13 y nftables, que realiza NAT y filtrado entre zonas.

Zona	Red	Contenido
WAN	172.20.17.0/24	Salida a Internet / tránsito
SOC	10.20.10.0/24	Estación red team y SIEM (Wazuh)
DMZ	10.20.20.0/24	Web corporativa (nginx)
Servicios	10.20.30.0/24	Servidor de ficheros (Samba)

La política del cortafuegos aísla la DMZ y la red de servicios entre sí y respecto del SOC, permitiendo únicamente la salida controlada a Internet y la publicación de la web mediante DNAT. Se verificó que la DMZ no puede alcanzar la red interna.

4. Infraestructura del cliente (Apex Gestoría)

La infraestructura del cliente se aloja en un nodo distinto ('pve2'), garantizando una separación física real respecto de JAMSEC. Dispone de su propio cortafuegos, una DMZ con la web pública y una LAN interna con la base de datos y un servidor de ficheros.

Con fines de auditoría se introdujeron vulnerabilidades representativas de entornos reales: inyección SQL en la web, subida de ficheros sin validación, base de datos con superusuario remoto y contraseña débil, FTP con acceso anónimo, credenciales SSH débiles, segmentación deficiente y ausencia de cifrado en tránsito.

5. Monitorización: IDS/IPS/SIEM

Se desplegó Wazuh 4.12 (gestor, indexador y panel) como SIEM en el SOC de JAMSEC, con agentes instalados en las siete máquinas de ambas infraestructuras para la monitorización basada en host (HIDS) y la recolección de logs. Para evitar romper la segmentación, los agentes se comunican con el gestor a través de una interfaz dedicada en la red de tránsito.

Adicionalmente se instaló Suricata como IDS de red en los dos cortafuegos, integrando sus alertas en Wazuh. El conjunto proporciona visibilidad sobre ambas infraestructuras de forma centralizada.

6. Auditoría de seguridad

Desde una estación de red team situada en el SOC se ejecutó una auditoría de caja negra siguiendo el marco PTES y el OWASP Top 10, puntuando los hallazgos con CVSS v3.1. Se logró el compromiso total del cliente y la exfiltración de datos personales y financieros desde la red interna, encadenando varias debilidades.

El resultado se resume en 3 hallazgos críticos, 4 altos y 2 medios. El detalle figura en el informe técnico; la versión para dirección, en el informe ejecutivo. El SIEM registró la actividad del ataque (escaneo, fuerza bruta, accesos), demostrando capacidad de detección.

7. Incidencias y soluciones

Incidencia	Solución aplicada
Conflictos de IP en la red de tránsito compartida del aula	Verificación de IPs libres (ping + ARP) desde varios nodos antes de asignar; reasignación de las WAN afectadas
Instalador de Wazuh incompatible con Debian 13 (paquete retirado)	Parcheo de la lista de dependencias del instalador
Agentes Wazuh más nuevos que el gestor (rechazo de enrolamiento)	Fijación de la versión del agente a la del gestor (4.12.0)
Falsos positivos masivos de Suricata sobre virtio	Desactivación de offloads de NIC y captura a un solo hilo
Cortafuegos del cliente sin memoria al cargar Suricata	Ampliación de RAM de la VM (reinicio de VM, permitido)

8. Conclusiones

El proyecto cumple los objetivos planteados: se han desplegado dos infraestructuras empresariales separadas y funcionales, una solución de monitorización IDS/IPS/SIEM que cubre ambas, y una auditoría de intrusión completa con sus informes técnico y ejecutivo. Todo el trabajo es reproducible y está documentado y versionado.

La auditoría evidencia la importancia de la defensa en profundidad: la segmentación de red, la gestión de credenciales, la validación de entradas y el cifrado son controles que, combinados, habrían impedido la cadena de ataque demostrada.

9. Anexos

El código, las configuraciones (cloud-init, nftables), los scripts de automatización, las evidencias de la auditoría y los informes se encuentran en el repositorio del proyecto, organizados según se describe en su fichero README. La documentación técnica por fases está en el directorio docs/.